

Dar Tech — Roles, Permissions & Security Expansion

Proposed authorization and security framework

Classification: PROPOSED EXPANSION. Permission rules must be approved before implementation.

1. Authentication vs Authorization

Authentication answers who the user is. Authorization answers what that user can see and do. The system should keep these concerns separate.

2. Proposed Permission Model

Resource	View	Create	Edit	Delete/Archive	Sensitive actions
Projects	✓	✓	✓	Policy	—
Customers	✓	✓	✓	Policy	—
Employees	✓	—	Policy	Policy	Account management
Contracts	✓	✓	✓	Policy	—
Invoices	✓	✓	✓	Policy	—
Finance	Policy	Policy	Policy	Policy	Financial changes
Licenses	✓	✓	Policy	Policy	Generate / activate / revoke
Warranty	✓	✓	✓	Policy	Change warranty dates/terms
Follow-ups	✓	✓	✓	Policy	—
Client Resources	Policy	✓	✓	Policy	Publish to client
Settings	Policy	Policy	Policy	Policy	System configuration

3. Security Controls

- Individual employee accounts; no shared employee credentials.
- SSO integration for employee authentication.
- Account activation/deactivation.
- Session timeout and sign-out.
- Least-privilege access.
- Protection of financial, customer and license data.
- Audit trail for sensitive changes.
- Secure file access; client resources must not be publicly exposed.
- Server-side authorization checks; UI hiding alone is not security.

4. Important

The exact role names and permission matrix are intentionally not finalized here. This is the architecture direction for the next requirements workshop.